

Security+ 2.4 · Physical Attacks

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4** —
Physical Attacks (4:04) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Physical attacks include brute force (cutting locks, forcing doors), RFID cloning (copying NFC access badges), and environmental attacks (jumping fences, breaking through walls). Defenses include mantraps/vestibule access control, badge plus PIN (physical two-factor authentication), cameras, alarms, and monitoring RFID logs for unusual access times.

High-Yield Core Concepts Tested on Exam

- RFID cloning with a ~\$500 device copies a proximity badge
- Physical defense: mantrap, badge with PIN (two-factor), cameras and alarms
- Brute force physical attack: cutting locks or forcing doors
- Environmental attack: jumping fences or breaching walls

Exam Tips & Classic Scenarios

- 'clones an access badge' = RFID cloning
- 'tailgating through a secure door' = physical intrusion (mantrap prevents)
- 'badge and PIN required for entry' = physical two-factor authentication

Typical Exam Scenario: Scenario: 'An intruder copies an employee badge and enters the server room' = RFID cloning.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — Physical Attacks)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An attacker uses RFID to clone employee badges and access restricted areas. What type of physical attack is this?

- A)** Tailgating
- B)** Shoulder surfing
- C)** Credential cloning
- D)** Dumpster diving

2. Decoy system that pretends to be vulnerable to attract and study attackers:

- A)** Honeypot
- B)** DMZ
- C)** Bastion host
- D)** Jump box

3. Corporate scenario (Physical Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'RFID cloning with a \$500 device copies a badge (proximity)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: RFID cloning with a \$500 device copies a badge (proximity)...

4. Corporate scenario (Physical Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Physical defense: mantrap, badge with PIN (2-factor), cameras+alarms'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Physical defense: mantrap, badge with PIN (2-factor), cameras+alarms.

5. Corporate scenario (Physical Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'clones an access badge' = RFID cloning'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'clones an access badge' = RFID cloning...

6. Corporate scenario (Physical Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: "intruder copies an employee badge and enters the server room" = RFID cloning.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Scenario: "intruder copies an employee badge and enters the server room"...

7. Corporate scenario (Physical Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'RFID cloning with a \$500 device copies a badge (proximity).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: RFID cloning with a \$500 device copies a badge (proximity)...

8. Corporate scenario (Physical Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Physical defense: mantrap, badge with PIN (2-factor), cameras+alarms'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Physical defense: mantrap, badge with PIN (2-factor), cameras+alarms...
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Physical Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'clones an access badge' = RFID cloning. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'clones an access badge' = RFID cloning...
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Physical Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: intruder copies employee badge and enters server room' = RFID cloning. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'intruder copies employee badge and enters server room' = RFID cloning
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) C — Credential cloning.

✓ **Why it's correct:** The correct answer is 'Credential cloning'. Credential cloning occurs when an attacker copies the data from an access card (such as RFID badges or proximity cards) to another device, allowing unauthorized access. In the scenario, using RFID to copy the badge signal and replicate it onto a blank card is a classic example of physical credential cloning. CompTIA Security+ covers physical attacks and countermeasures, such as using encrypted cards or mutual authentication to prevent cloning.

✗ **Why the others are wrong:**

- *Tailgating:* Tailgating is the practice of physically following an authorized person through a secure door without using one's own credentials. It does not involve cloning cards or RFID; it is a passive physical intrusion. The option is incorrect because the scenario describes electronic copying of credentials, not entry by proximity.
- *Shoulder surfing:* Shoulder surfing is direct observation over someone's shoulder to obtain information such as passwords or PINs. It does not involve RFID or badge cloning. The option is incorrect because it is a visual observation technique, not electronic duplication.
- *Dumpster diving:* Dumpster diving is searching through trash for discarded information (documents, media) that could be useful to an attacker. It has no relation to RFID or credential cloning. The option is incorrect because it involves recovering discarded data, not intercepting and copying card signals.

2) A — Honeypot.

✓ **Why it is correct:** A honeypot is a decoy system designed to appear vulnerable and attract attackers, with the goal of studying their tactics, techniques, and procedures (TTPs), diverting attention from real systems, and gathering threat intelligence. It can be low-interaction (simulates services) or high-interaction (isolated real system). It is a proactive security and detection control, per SY0-701 objectives 3.2 (security implementation) and 4.8 (monitoring and detection). The question describes exactly a decoy system that pretends to be vulnerable to attract and study attackers, which is the definition of a honeypot.

✗ **Why the others are wrong:**

- *DMZ:* A DMZ (Demilitarized Zone) is a physical or logical subnetwork that sits between the trusted internal network and the untrusted external network (e.g., the Internet). It hosts public services (web, email, DNS) to prevent external attacks from directly reaching the internal network. A DMZ is not a decoy system; it is a network segment designed to expose services in a controlled manner. It does not pretend to be vulnerable nor aims to attract and study attackers. The question asks for a decoy system, not a segmentation architecture.
- *Bastion host:* A bastion host is a heavily protected system exposed to an untrusted network, typically acting as a single entry point for remote administration or as a proxy. It is hardened and monitored, but it is not a decoy; it is a defense point. Its purpose is to be secure, not to appear vulnerable. The question describes a system that pretends to be vulnerable to attract attackers, which is the opposite of a bastion host, which is designed to be as secure as possible.
- *Jump box:* A jump box (or jump server) is an intermediary system used to access and administer devices in a segregated network, such as a DMZ or internal network. It centralizes administrative access, enforces strong authentication, and logs activities. It is not a decoy; it is an access control tool. It does not pretend to be vulnerable nor aims to study attackers. The question asks for a decoy system, not an administrative jump point.

3) D — Implement the corresponding solution: RFID cloning with a \$500 device copies a badge (proximity)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Physical Attacks): RFID cloning with a \$500 device copies a badge (proximity). RFID badges can be cloned using relatively inexpensive hardware, allowing attackers to gain physical access. Mitigations include using encrypted badges, multi-factor authentication, and monitoring.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) D — Implement the corresponding solution: Physical defense: mantrap, badge with PIN (2-factor), cameras+alarms..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Physical Attacks): Physical defense: mantrap, badge with PIN (2-factor), cameras+alarms. These controls provide layered physical security: mantraps prevent tailgating, badge+PIN enforces two-factor authentication, and cameras+alarms enable detection and response. They are essential for protecting facilities and assets.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: 'clones an access badge' = RFID cloning....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Physical Attacks): 'clones an access badge' = RFID cloning.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: Scenario: "intruder copies an employee badge and enters the server room"....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Physical Attacks): Scenario: "intruder copies an employee badge and enters the server room" = RFID cloning. RFID cloning involves copying the data from an RFID badge to another device to gain unauthorized physical access. Defenses include using more secure badge technologies (e.g., MFA, encrypted badges) and monitoring access logs.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: RFID cloning with a \$500 device copies a badge (proximity)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Physical Attacks): RFID cloning with a \$500 device copies a badge (proximity). Proximity cards using RFID are vulnerable to cloning if not protected with encryption or challenge-response mechanisms, allowing attackers to duplicate access badges and gain unauthorized physical entry.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: Physical defense: mantrap, badge with PIN (2-factor), cameras+alarms....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Physical Attacks): Physical defense: mantrap, badge with PIN (2-factor), cameras+alarms.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

9) C — Implement the corresponding solution: 'clones an access badge' = RFID cloning....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Physical Attacks): 'clones an access badge' = RFID cloning.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

10) A — Implement the corresponding solution: Scenario: 'intruder copies employee badge and enters server room' = RFID cloning.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Physical Attacks): Scenario: 'intruder copies employee badge and enters server room' = RFID cloning. RFID cloning involves copying the data from an RFID badge to another device to gain unauthorized physical access.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.